

Real-time questions during class – Claper

- You can use Claper for asking questions during the lecture.
- We will answer your questions at the end of the lecture.
- Go to:
<https://claper.fi.muni.cz/e/pb177>



M U N I
F I

Attack lifecycle

MITRE ATT&CK, Reconnaissance

PB177 Cyber Attacks

September 24, 2026

Jan Vykopal

Attack Lifecycle

Cyber attack steps

- A **cyber attack** is an attempt to gain **unauthorized access** to system services, resources, or information, or an **attempt to compromise** system **integrity, availability, or confidentiality**.
- Complex attacks consist of **several steps (phases)** that need to be done **to accomplish the ultimate goal**, e.g., exfiltrating sensitive information.
- Understanding these steps helps defenders to prevent and mitigate attacks.
- General models of cyber attacks describe an **attack lifecycle**.

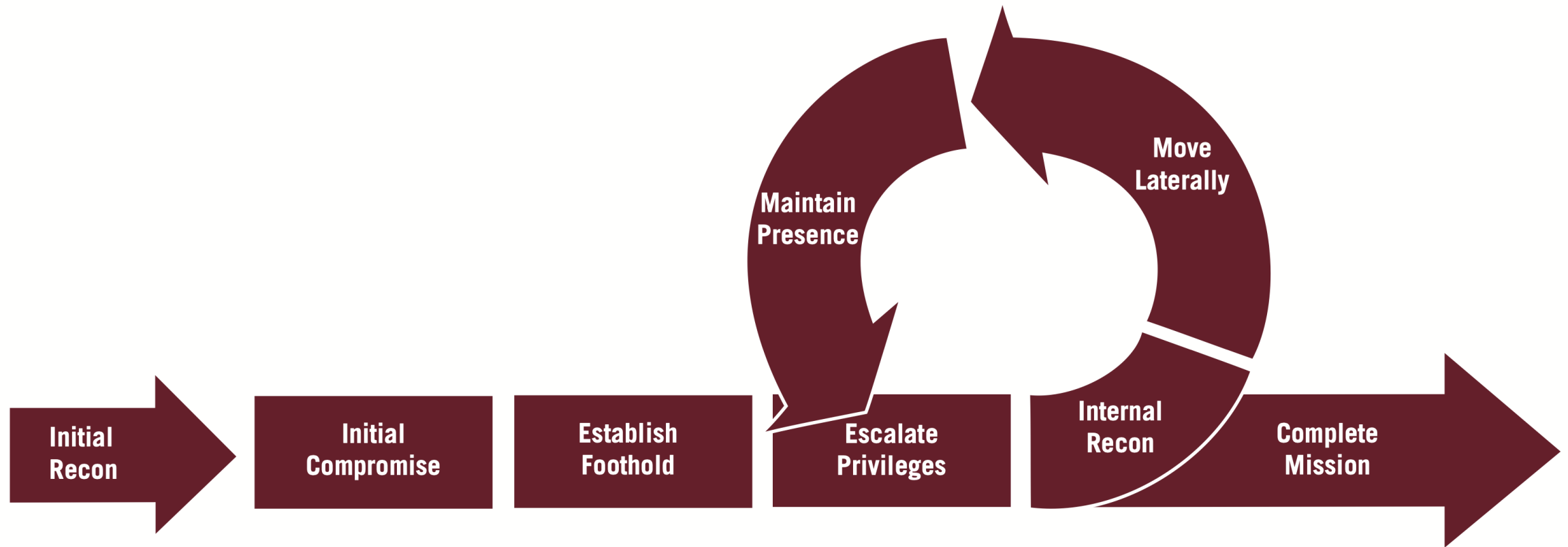
Cyber Kill Chain (Lockheed Martin)

1. **Reconnaissance** – Identification of the targets
2. **Weaponization** – Preparation of the operation
3. **Delivery** – Launching of the operation
4. **Exploitation** – Gaining access to victim
5. **Installation** – Establishing beachhead at the victim
6. **Command & Control (C2)** – Remote controlling of the implants
7. **Action on objectives** – Achieving the mission's goal

Cyber Kill Chain – examples of attack steps

1. **Reconnaissance** – harvesting email addresses, discover internet-facing servers,
2. **Weaponization** – selecting backdoor implant and appropriate command and control infrastructure for operation,
3. **Delivery** – malicious email, compromised websites,
4. **Exploitation** – opening attachment of malicious email, visiting the compromised website,
5. **Installation** – installing backdoor implant on client victim,
6. **Command & Control (C2)** – open two-way channel to C2 infrastructure,
7. **Action on objectives** – exfiltrating sensitive information.

Attack Lifecycle Model (Mandiant)



MITRE ATT&CK

MITRE ATT&CK

- **Knowledge base** of adversarial techniques **based on real-world observations** available online at <https://attack.mitre.org>.
- Focuses on **how adversaries interact with systems** during an operation, reflecting the various phases of an attack lifecycle.
- Attempt to provide **more useful information for defenders** than high-level life cycles such as Cyber Kill Chain.
- Organized in a series of technology domains:
 - **Enterprise** – traditional enterprise networks and cloud technologies
 - **Mobile** – mobile communication devices
 - **ICS** – industrial control systems

MITRE ATT&CK components

- **Tactics** represent **why** – the reason an adversary is performing an action.
- **Techniques** represent **how** adversaries achieve tactical goals by performing an action.
- **Sub-techniques** are more specific or lower-level descriptions of adversarial behaviour.
- **Procedures** are specific implementations and uses of (sub)techniques in the real world (tools, commands, scripts).

MITRE ATT&CK Enterprise tactics

The adversary's tactical goal: the reason for performing an action.
15 tactics in total:

- 1. Reconnaissance** – gather information useful for planning future operations
- 2. Resource Development** – establish resources for supporting operations
- 3. Initial Access** – get into the target network
- 4. Execution** – run malicious code
- 5. Persistence** – maintain foothold
- 6. Privilege Escalation** – gain higher-level permissions
- 7. Stealth** – to hide and conceal actions, appearing as normal behavior

MITRE ATT&CK Enterprise tactics

- 8. Defense Impairment** – break security tooling so defenders can't see or trust what's happening
- 9. Credential Access** – steal account names and passwords
- 10. Discovery** – figure out the target environment
- 11. Lateral Movement** – move through the environment
- 12. Collection** – gather data of interest to the attacker's goal
- 13. Command and Control** – communicate with compromised systems to control them
- 14. Exfiltration** – steal data
- 15. Impact** – manipulate, interrupt, or destroy systems and data

MITRE ATT&CK Enterprise (sub)techniques

- Techniques = **how** adversaries achieve tactical goals
- **222 techniques** and **475 sub-techniques** in total! And still increasing.
- Example of a technique for gathering information useful for planning future operations (= Reconnaissance):
[Phishing for Information](#)
- This technique contains four subtechniques:
 - Spearphishing Service
 - Spearphishing Attachment
 - Spearphishing Link
 - Spearphishing Voice

MITRE ATT&CK Enterprise (sub)techniques II

Each (sub)technique contains

- **description** with links to external resources,
- **procedure examples** – documented use in practice,
- **mitigations** – countermeasures for defenders,
- **detection strategies** – high-level approaches for detecting the (sub)technique.

See [Phishing for Information: Spearphishing Attachment](#) as an example.

MITRE ATT&CK use cases

- **Detections and Analytics** – defenders can develop analytics for detecting the adversary techniques.
- **Threat Intelligence** – analysts can use a common language to structure, compare, and analyze threat intelligence.
- **Adversary Emulation and Red Teaming** – red teams can use a common language and framework to emulate specific threats and plan their operations.
- **Assessment and Engineering** – assessing the organization's capabilities and driving engineering decisions, such as what tools or logging should be implemented.

Detections and Analytics

- ATT&CK shows **approaches** and **data sources useful to detect techniques**.
- Defenders can deploy the sources and process collected data (run analytics) to detect techniques.
- Analytics are prone to false positives, needs to be revised and tested.
- Example: [Detection of Phishing for Information](#) can be done using three log sources. While **application logs** can be searched for numerous accounts receiving messages from a single unusual/unknown sender, network traffic flows can exhibit anomalous patterns.

Adversary Emulation and Red Teaming

- Testing whether deployed detections and analytics work as expected.
- Process:
 1. Choose an ATT&CK technique
 2. Choose a test for that technique
 3. Execute the test procedure
 4. Analyze the detections of the procedure
 5. Make improvements to the defenses
- Open-source library of tests: [Atomic Red Team](#)

Adversary Emulation and Red Teaming II

Example:

- Technique: Disable or Modify Tools: Clear Linux or Mac System Logs
- Atomic test: #2 - rm -rf

Selected MITRE ATT&CK techniques

Reconnaissance

Reconnaissance (recon)

- One of 15 ATT&CK Enterprise tactics.
- Consists of techniques that involve adversaries **actively or passively gathering information that can be used to support targeting.**
- These information are **used in other phases of the lifecycle** to:
 - plan and execute Initial Access (see next week),
 - scope and prioritize post-compromise objectives (see later), or
 - drive and lead further Reconnaissance efforts.
- Recon techniques **can be detected but not easily mitigated.**
- One mitigation is **minimizing** the amount and sensitivity of **data available to external parties.**

Reconnaissance – techniques

- Active Scanning
- Gather Victim Host Information
- Gather Victim Identity Information
- Gather Victim Network Information
- Gather Victim Org Information
- Phishing for Information
- Query Public AI Services
- Search Closed Sources
- Search Open Technical Databases
- Search Open Websites/Domains
- Search Threat Vendor Data
- Search Victim-Owned Websites

See <https://attack.mitre.org/tactics/TA0043/>.

Active Scanning

- **Active reconnaissance** scans to gather information that can be used during targeting.
- Probing victim infrastructure **via network traffic**, as opposed to other forms of reconnaissance that do not involve direct interaction.

Subtechniques:

- Scanning IP Blocks
- Vulnerability Scanning
- Wordlist Scanning

Active Scanning: Scanning IP Blocks

- Adversaries scan victim **IP blocks** to **gather information that can be used during targeting**.
- Public IP addresses may be allocated to organizations **by block**, or a **range of sequential addresses**.
- Attackers search for **IP addresses** that are **actively in use** and/or **software used** at hosts and **SW versions**.

Active Scanning: Scanning IP Blocks II

- Types of scans:
 - **TCP, UDP, ICMP** – sending ordinary or malformed packets of the given network protocol and waiting for a host response,
 - TCP SYN scanning – sending TCP packets with SYN flags set only
 - **Horizontal** – sending requests to the same port on different hosts,
 - **Vertical** – sends requests to different ports on the same host.

Active Scanning: Scanning IP Blocks III

- Tools: [Nmap](#) ("Network Mapper") – exercised in the first seminar (lab)
- Detection: Monitoring network data for uncommon data flows. May have high false positive rate.
- Mitigation: Blocking some host response (such as ICMP replies) or network ports that do not provide public services (such as network printers).
- See <https://attack.mitre.org/techniques/T1595/001/> for more details.
- The same applies to the technique [Gather Victim Network Information: IP Addresses](#).

Active Scanning: Wordlist Scanning

- Iterative **probing of infrastructure** using **brute-forcing and crawling techniques**.
- The goal is **identification of content and infrastructure** rather than the discovery of valid credentials.
- Examples:
 - enumerating web pages and directories to find vulnerable pages or hidden administrative portals,
 - enumerate public and private buckets on cloud infrastructure.
- Tools: [dirb](#) (web content scanner, exercised in seminar), [DirBuster](#), [Gobuster](#) (web scanners), [yes3-scanner](#) (Amazon bucket finder and crawler)

Active Scanning: Wordlist Scanning II

- Detection: analysis of network traffic or application logs
- Mitigation: removing or disabling access to any systems, resources, and infrastructure that are not explicitly required to be available externally.
- See <https://attack.mitre.org/techniques/T1595/003/> for more.

Active Scanning: Vulnerability Scanning

- Adversaries scan **victims for vulnerabilities** that can be used during targeting.
- Checks if the **configuration of a target host/application** aligns with the target of a **specific exploit** the adversary seek to use.
- Vulnerability scans harvest running **software and version numbers** via **server banners, listening ports, or other network artifacts**.

Active Scanning: Vulnerability Scanning II

- Tools: Nmap (Nmap Scripting Engine), [Metasploit](#), [Nessus](#), [OpenVAS](#)
- Detection: Analysis of network traffic content and flow.
- Mitigation: Minimizing the amount and sensitivity of data available to external parties.
- See <https://attack.mitre.org/techniques/T1595/002/> for more.

Gather Victim Network Information

Gathering information about the networks that can be used during targeting.

Subtechniques:

- Domain Properties
- DNS
- Network Trust Dependencies
- Network Topology
- IP Addresses
- Network Security Appliances

Gather Victim Network Information: DNS

- DNS information may include a variety of details, including registered name servers, records that outline addressing for a target's subdomains, mail servers, and other hosts.
- DNS, MX, TXT, and SPF records may reveal the use of third-party cloud and SaaS providers, such as Office 365 or Google Suite.

Gather Victim Network Information: DNS II

– Example: dig MX muni.cz

```
;; ANSWER SECTION:
muni.cz.          7200    IN      MX      50 relay.muni.cz.
```

– Example: dig TXT muni.cz

```
;; ANSWER SECTION:
muni.cz.          3600    IN      TXT      "MS=ms85476152"
muni.cz.          3600    IN      TXT      "google-site-verification=ftbJc_Wklu5o5bA5VYCNo"
muni.cz.          3600    IN      TXT      "v=spf1 ip4:147.251.14.49 ip4:88.86.101.25 ip4:"
"include:spf.protection.outlook.com include:_spf.google.com ~all"
muni.cz.          3600    IN      TXT      "atlassian-domain-verification=Hil6B1jQ7/Dlw6gd"
muni.cz.          3600    IN      TXT      "atlassian-sending-domain-verification=54f720d3"
muni.cz.          3600    IN      TXT      "status-page-domain-verification=xx37pp3swrw"
```

Gather Victim Network Information: DNS III

- Tools: dig, nslookup (DNS lookup utilities), [DNSDumpster.com](https://dnscat.org/) (passive DNS)
- Detection: hard to distinguish between legitimate traffic and recon
- Mitigation: cannot be easily mitigated
- See <https://attack.mitre.org/techniques/T1590/002/>.

Gather Victim Org Information

- Information about an organization may include a variety of details, including the names of divisions/departments, specifics of business operations, and the roles and responsibilities of key employees.
- Subtechniques:
 - Determine Physical Locations
 - Business Relationships
 - Identify Business Tempo
 - Identify Roles

Gather Victim Org Information II

Example: name, email, office and social media profiles of the rector of MU:

- <https://www.muni.cz/lide/2002-martin-bares>
- <https://www.muni.cz/mapa/kancelar-2286>
- <https://www.facebook.com/martin.bares.125>
- <https://x.com/martinbares11>

Gather Victim Org Information III

- Useful for further recon, establishing operational resources (Establish Accounts or Compromise Accounts, see next week), and/or Initial access (such as Phishing).
- Tools: web browser (search engines), mail client (phishing)
- Detection: difficult
- Mitigation: controlling level of **publicly** available information
- See <https://attack.mitre.org/techniques/T1591/>.
- The same applies to the technique [Search Victim-Owned Websites](#).

Phishing for Information

- Sending phishing messages to **elicit sensitive information** that can be used during targeting.
- **An attempt to trick targets** into divulging information, frequently credentials or other actionable information.
- This techniques in Reconnaissance (gathering data) differs to Phishing techniques in Initial Access (executing malware).
- **Spear phishing** = phishing targeted at a specific individual, company, or industry.

Phishing for Information II

- Subtechniques:
 - Spearphishing Service
 - Spearphishing Attachment
 - Spearphishing Link
 - Spearphishing Voice
- Tools: [Evilginx](#), [GoPhish](#)
- Detection – monitoring application logs and network traffic for:
 - suspicious email activity (numerous accounts receiving messages from a single unusual/unknown sender),
 - references (URL) to uncategorized or known-bad sites,
 - call logs from corporate devices to identify patterns of potential voice phishing.

Phishing for Information III

- Mitigation:
 - Use **anti-spoofing and email authentication** mechanisms to filter messages based on validity checks of the sender domain (using SPF) and integrity of messages (using DKIM).
 - **User training**
- See <https://attack.mitre.org/techniques/T1598/> for more.

Search Open Technical Databases

- Searching in **freely available technical databases** for information about victims that can be used during targeting.
- **Someone else** has already actively scanned networks.
- Subtechniques:
 - DNS/Passive DNS
 - WHOIS
 - Digital Certificates
 - CDNs
 - Scan Databases
- Tools: [Merklemap](#) (subdomain search engine), [Shodan.io](#) (device search engine)

Output of search for muni.cz subdomains

HOSTNAME	COMMON NAME	FIRST SEEN
www.muni.cz	www.muni.cz	16. 9. 2025
preview-novy-web-dev-ka6kj1-mtpijr.wet.czs.muni.cz	preview-novy-web-dev-ka6kj1-mtpijr.wet.czs.muni.cz	16. 9. 2025
biodata.recetox.muni.cz	geoserver.recetox.muni.cz	15. 9. 2025
qa-biodata.recetox.muni.cz	qa-data-collector.cetoc.muni.cz	15. 9. 2025
botanickazahrada.sci.muni.cz	botanickazahrada.sci.muni.cz	15. 9. 2025
preview-novy-web-dev-ka6kj1-6j3aed.wet.czs.muni.cz	preview-novy-web-dev-ka6kj1-6j3aed.wet.czs.muni.cz	15. 9. 2025
dev.wet.czs.muni.cz	dev.wet.czs.muni.cz	15. 9. 2025
edivebuild.phil.muni.cz	edivebuild.phil.muni.cz	14. 9. 2025
beta-akutne.iba.muni.cz	beta-akutne.iba.muni.cz	12. 9. 2025
rt.svc.csirt.muni.cz	rt.svc.csirt.muni.cz	12. 9. 2025

Search Open Technical Databases II

- Detection: outside of the scope of enterprise monitoring
- Mitigation: cannot be easily mitigated, the only mitigation is blocking agents of technical DBs that gather the data
- See <https://attack.mitre.org/techniques/T1596/005/> for more.

References

References I

Lockheed Martin Cyber Kill Chain

- [Applying Cyber Kill Chain® Methodology to Network Defense](#)
- [Intelligence-Driven Computer Network Defense Informed by Analysis of Adversary Campaigns and Intrusion Kill Chains](#)
- [Cybersecurity in practice: The vigilant logic of kill chains and threat construction](#)

Mandiant Attack Lifecycle Model

- [APT1 Exposing One of China's Cyber Espionage Units](#)

References II

MITRE ATT&CK

- [ATT&CK Fundamentals Training](#) (videos)

Other announcements – The Catch CTF

- An individual competition, but teamwork is not prohibited.
- Best contestants will receive valuable prizes.
- Register at <https://www.thecatch.cz> from October 5.

Questions, answers, and feedback in Claper

- You can use Claper for asking questions during the lecture.
- We will answer your questions at the end of the lecture.
- Go to:
<https://claper.fi.muni.cz/e/pb177>
- **Please provide us with feedback:**
How can today's class be improved?



MUNI

FI